External attack surface: OSINT to verified exposure

An expert, authorization-first project that walks the external attack surface end to end: certificate transparency with crt.sh, subdomain and asset discovery with OWASP Amass, internet exposure with Shodan, active verification with Nmap, vulnerability templating with Nuclei, credential exposure with Have I Been Pwned domain search, then targeted web deepening with ffuf and Burp Suite. It ends where it must: proving detection of the scanning activity and remediating what the chain found. Defensive use only, on your own systems or with written permission.

10 phases | 24 steps | Tick each item when its "done when" criterion is true

Phase 1 Authorize the engagement, prove ownership and notify defenders about 1–3 days

- [ ] **1.1 Get written authorization that names domains, public ranges and out-of-scope systems**
  A signed or ticketed approval names registered domains, public IP/CIDR ranges, cloud accounts that publish public endpoints, the date window, allowed techniques and a stop-contact
- [ ] **1.2 Prove ownership before any active packet leaves your assessment host**
  Every domain and CIDR in scope has ownership evidence (registrar, DNS control, cloud public-IP inventory or ISP assignment) attached to the engagement log
- [ ] **1.3 Notify the SOC and agree how engagement scanning is marked**
  SOC has the window, the assessment source IPs, the jump-host identities and the expected volume of recon and active scanning

Phase 2 Certificate transparency with crt.sh about 0.5–1 day

- [ ] **2.1 Query crt.sh for every in-scope registered domain**
  For each in-scope domain you have an export of unique Common Names and SANs from crt.sh, with issue dates noted
- [ ] **2.2 Classify CT names: owned, retired, third-party, investigate**
  Every unique name is tagged owned-live, owned-retired, third-party/SaaS, or investigate — and only owned-live (plus approved investigate) proceeds

Phase 3 Asset and subdomain discovery with OWASP Amass about 1–2 days

- [ ] **3.1 Run Amass in passive mode against every in-scope domain**
  `amass enum -passive -d <domain> -o amass-passive.txt` (or equivalent) has completed for each domain and results are stored with the engagement log
- [ ] **3.2 Expand with approved active Amass techniques only inside scope**
  Any active Amass run is limited to confirmed-owned domains, documented in the RoE, and its output is diffed against the passive baseline
- [ ] **3.3 Publish the confirmed-owned asset inventory that later phases consume**
  A single inventory file lists hostname, resolved IPs, ownership tag, source (CT/Amass/DNS) and whether active scanning is approved

Phase 4 Internet exposure with Shodan about 0.5–1 day

- [ ] **4.1 Query Shodan for your confirmed-owned IPs, CIDRs and hostnames**
  Shodan results for in-scope IPs/hostnames are exported, with product banners, open ports and certificate subjects recorded
- [ ] **4.2 Turn Shodan hits into prioritized exposure candidates**
  Every unexpected internet-facing service has an owner, a business justification or a 'remove from internet' ticket draft

Phase 5 Active verification with Nmap about 1–2 days

- [ ] **5.1 Scan confirmed-owned targets with an explicit profile and rate limit**
  Nmap has run against the approved host/IP list with a documented profile (ports, timing, scripts) and raw output archived
- [ ] **5.2 Reconcile Nmap with Shodan and produce the verified exposure set**
  A verified exposure table lists host, port, service, product/version (if fingerprinted), Shodan-vs-now delta and owner

Phase 6 Templated vulnerability checks with Nuclei about 1–2 days

- [ ] **6.1 Pin Nuclei and templates, then run a scoped pass against verified hosts**
  Nuclei version and nuclei-templates commit/tag are recorded; a first pass has completed against the verified exposure set with output archived
- [ ] **6.2 Triage findings into verified, false-positive and accept-risk**
  Every Nuclei hit is classified with evidence, owner and next action; unverified hits do not enter the remediation backlog as facts

Phase 7 Credential exposure with Have I Been Pwned domain search about 0.5–1 day

- [ ] **7.1 Verify domains in HIBP and pull domain search results**
  Each in-scope email domain is verified in HIBP Domain Search (or queried via the authorized API) and results are stored as restricted evidence
- [ ] **7.2 Convert breach hits into identity actions**
  Privileged and high-risk accounts from the HIBP set have a documented action (reset, block legacy auth, phishing-resistant MFA, monitoring) or an explicit accept-risk

Phase 8 Deepen selected web apps with ffuf and Burp Suite about 2–5 days

- [ ] **8.1 Pick the web targets that deserve human depth**
  A written shortlist (typically a handful of apps) names URLs, environments, accounts, data sensitivity and whether destructive tests are allowed
- [ ] **8.2 Content discovery with ffuf under strict rate and scope controls**
  ffuf runs are limited to shortlisted hosts, with wordlists, rate, match/filter rules and output paths recorded
- [ ] **8.3 Authenticated application testing with Burp Suite**
  Burp project files exist for each shortlisted app, with scope locked to the named hosts and findings written up with request evidence

Phase 9 Prove detection of the external recon and scanning path about 1–2 days

- [ ] **9.1 Correlate edge, DNS and IDS/WAF alerts with the engagement timeline**
  For each active phase (Amass active, Nmap, Nuclei, ffuf) the SOC can show matching telemetry or a ticketed gap
- [ ] **9.2 Confirm identity-plane visibility for HIBP-driven and app-test accounts**
  Entra sign-in and audit logs show the test accounts and any forced-reset activity; gaps are ticketed

Phase 10 Remediate exposure, retest and close the engagement about 1–4 weeks

- [ ] **10.1 Remove or lock down what should never have been on the internet**
  Every critical verified exposure has a closed change (removed public listener, IP allow list, SSO/WAF in front, or accepted risk with expiry)
- [ ] **10.2 Close the identity and application findings from HIBP, Nuclei and Burp**
  HIBP-driven resets and CA changes are done for priority accounts; confirmed Nuclei/Burp findings have owners and due dates
- [ ] **10.3 Retest the headline paths, wipe the loot and schedule continuous discovery**
  A dated retest shows the critical exposures closed, all engagement data is wiped or vaulted, and continuous external discovery is scheduled

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.com/guides/external-attack-surface-osint.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.